

GHOSTFACE — Cryptographic Inventory

Prepared by: Ghostface Limited (NZ)

Product: GHOSTFACE — end-to-end encrypted mobile messaging app (iOS / Android)

Date: 19 August 2026 · **Revised:** 31 August 2026 (rev. 2 — see §6)

Purpose: Supporting document for export-control classification review. Factual inventory of all cryptography used in the product, its sources, and its purpose. Prepared for review by legal counsel — this document states technical facts, not legal conclusions.

1. Summary

GHOSTFACE is a consumer end-to-end encrypted (E2EE) messaging and calling application, freely available to the general public through the Apple App Store and Google Play. Its encryption exists solely to protect users' personal communications in transit and at rest. It performs no encryption function beyond that data-security purpose.

Every cryptographic algorithm used is a **standard, published algorithm** drawn from NIST FIPS standards, IETF RFCs, and peer-reviewed public specifications. The cryptography is implemented entirely using widely-used open-source libraries — the `@noble/*` JavaScript libraries for the protocol primitives, and `react-native-argon2` for the Argon2id recovery-PIN derivation — together with the operating system's own cryptographic random-number and key-storage facilities. **No proprietary or secret cryptographic algorithm has been designed or implemented.**

The protocol design follows the publicly-documented Signal protocol family (X3DH + Double Ratchet), extended for post-quantum security using the same hybrid approach published by Signal (PQXDH) and Apple (iMessage PQ3).

2. Cryptographic primitives

Function	Algorithm	Standard	Source library (version)
Authenticated encryption (messages, media, storage)	ChaCha20-Poly1305	RFC 8439	@noble/ciphers 2.1.1
Key agreement (classical)	X25519 (ECDH on Curve25519)	RFC 7748	@noble/curves 2.0.1
Digital signatures	Ed25519	RFC 8032	@noble/curves 2.0.1
Post-quantum key encapsulation	ML-KEM-768	NIST FIPS 203	@noble/post-quantum 0.6.1
Hashing	SHA-256, SHA-512	FIPS 180-4	@noble/hashes 2.0.1
Key derivation (session)	HKDF-HMAC-SHA256	RFC 5869	@noble/hashes 2.0.1
Key derivation (PIN/passphrase)	PBKDF2-HMAC-SHA256, 600,000 iterations	RFC 2898 / NIST SP 800-132	@noble/hashes 2.0.1
Key derivation (recovery PIN)	Argon2id — t=3, m=64 MiB, p=1, 32-byte output	RFC 9106	react-native-argon2 4.0.0 (native)
Message authentication	HMAC-SHA256	RFC 2104 / FIPS 198-1	@noble/hashes 2.0.1
Random number generation	OS CSPRNG — SecRandomCopyBytes (iOS), java.security.SecureRandom (Android)	Platform-provided	react-native-get-random-values 1.11.0, expo-crypto
Key storage	iOS Keychain / Android Keystore	Platform-provided	expo-secure-store

All of the above are standard published algorithms. None is modified.

3. Protocols and how the primitives are combined

GHOSTFACE composes the standard primitives above into the publicly-documented Signal protocol design:

Initial key agreement — X3DH, extended to PQXDH. New sessions are established using Signal's Extended Triple Diffie-Hellman (X3DH) over X25519, with prekey signatures verified via Ed25519. Where both parties support it, the handshake additionally performs an ML-KEM-768 key encapsulation and mixes the resulting shared secret into the session key — identical in structure to Signal's published PQXDH specification. The app requires this post-quantum step for all new sessions.

Ongoing messaging — Double Ratchet. Established sessions use Signal's Double Ratchet algorithm: a Diffie-Hellman ratchet (X25519) plus symmetric-key ratchets, with per-message keys deriving forward

secrecy and post-compromise security. Each message is encrypted with ChaCha20-Poly1305 under a per-message key.

Key-derivation functions. Root- and chain-key derivation uses HKDF-HMAC-SHA256 (RFC 5869) throughout — the standard construction used by the Signal protocol itself.

Post-quantum continuous rekey (`kdfRkPQ`). For PQ-enabled sessions, the root-key update mixes the post-quantum shared secret into the ratchet. This is implemented as a single HKDF-HMAC-SHA256 call whose input keying material is the concatenation of (a) the X25519 Diffie-Hellman output and (b) the ML-KEM-768 shared secret, with a distinct domain-separation label. **It is standard HKDF-SHA256 applied to two standard shared secrets — it defines no new cryptographic algorithm or primitive.** Its purpose and structure mirror the continuous post-quantum rekeying published in Apple's iMessage PQ3 design.

Data at rest. Locally-stored data (message history, keys) is encrypted with ChaCha20-Poly1305 under a master key held in the OS keychain (iOS Keychain / Android Keystore). PIN/passphrase-derived keys use PBKDF2-HMAC-SHA256 at 600,000 iterations (OWASP-recommended).

Recovery-PIN key blinding (Argon2id). The 24-word recovery phrase is a reversible BIP39 encoding of the identity private key, so a leaked phrase alone would be total compromise. To prevent that, the key is blinded with a user-chosen 6-digit PIN before the phrase is generated:

```
phraseValue = identityKey XOR Argon2id(pin, salt)
```

- **Purpose:** make the recovery phrase useless on its own — restore requires both the phrase and the PIN. The PIN is never stored or transmitted.
- **Inputs:** the 6-digit PIN, and a per-identity salt derived deterministically as SHA-256 of a fixed domain-separation tag concatenated with the normalised alias. The salt is public and derivable by design: a salt requires uniqueness, not secrecy, and deriving it from the alias keeps the feature entirely client-side with nothing stored server-side.
- **Parameters:** Argon2id, 3 iterations, 64 MiB memory, parallelism 1, 32-byte output — chosen because an attacker holding the phrase can brute-force the PIN offline against the publicly-fetchable identity key, so each guess must be made expensive. Run in native code (`react-native-argon2`) as pure-JS Argon2 is prohibitively slow on the mobile JavaScript engine.
- **Output:** a 32-byte blinding value, combined with the identity private key by bitwise XOR.

It is the standard Argon2id function of RFC 9106, used conventionally as a password-based key-derivation function. It defines no new cryptographic algorithm or primitive, and performs no encryption — the derived value is used only to blind a key at rest on the user's own device.

Implemented in `artifacts/ghostface/lib/recoveryPin.ts`.

4. Nature and availability

- **Function:** data confidentiality and integrity for personal communications only.
- **Availability:** free consumer app, distributed to the general public through mainstream app stores; no restriction on class of user.
- **Cryptographic novelty:** none at the primitive level. The only non-verbatim element (`kdfRkPQ`) is a standard-HKDF composition of two standard shared secrets, matching published hybrid-PQ designs. Argon2id and the recovery-PIN blinding use the published function unmodified.

- **Key length / strength:** as specified by the underlying standards (e.g. 256-bit symmetric, Curve25519, ML-KEM-768 / NIST security category 3).
- **Open-source dependencies:** all cryptography via public open-source libraries — `@noble/*` for the protocol primitives and `react-native-argon2` for Argon2id; the app implements no cryptography in a closed or secret manner.

5. Implementation corrections (no change to algorithms or protocol)

This section records changes that correct **how** existing cryptography is implemented, without altering which algorithms are used, how the protocol is structured, or what the cryptography does.

Canonical encoding of AEAD associated data (Double Ratchet message headers).

Each Double Ratchet message is bound to its header by passing the header as associated data (AD) to ChaCha20-Poly1305. The AD was previously produced by serialising the header object to JSON. That is deterministic in practice for the present single implementation, but it is not a sound long-term invariant: a second implementation in another language, or an incidental change that reordered object keys, could produce a different AD for what should be an identical header.

The correction replaces JSON serialisation with a fixed, self-describing binary encoding: a constant magic value and protocol-version byte, a fixed field order and field count, fixed integer widths in big-endian order, raw key bytes rather than hex text, and explicit presence-and-length framing for the two optional post-quantum fields so that a field is never simply omitted. A single function produces the AD for both encryption and decryption.

- **Algorithms:** unchanged — ChaCha20-Poly1305 (RFC 8439), as listed in §2.
- **Protocol:** unchanged — Double Ratchet header fields and their meaning are the same; only their byte-level representation as AEAD associated data changes.
- **Functionality:** unchanged — the AD continues to bind each message to its header, as before.
- **Nature:** encoding hygiene and cross-implementation robustness. No known exploit exists against the previous encoding; this is a correctness and future-proofing fix, not a patched vulnerability.

Implemented in `artifacts/ghostface/lib/doubleRatchet.ts`.

6. Changes since the 19 August 2026 version (rev. 1 → rev. 2)

Both items below were raised with counsel on 30 August 2026 and considered in counsel's response of **31 August 2026**, which confirmed that neither changes the classification analysis or the conclusions in the advice memorandum, and recommended that this inventory be updated to record them.

#	Item	Where	Nature
1	Argon2id added — recovery-PIN key blinding	§2 table, §3	Addition of a published, conventionally-applied key-derivation function (RFC 9106). Present in the codebase from 27 August 2026; omitted from rev. 1 in error.
2	AEAD associated-data canonical encoding	§5	Implementation correction only. Algorithms, protocol and functionality unchanged.

Neither item introduces a proprietary or novel cryptographic algorithm, and neither changes the set of primitives in §2 other than by recording Argon2id, which was already in use when rev. 1 was prepared.

This inventory reflects the state of the codebase as of 31 August 2026 and is provided to assist counsel's export-control classification assessment. It is a technical description prepared by the company, not a legal classification. Revision 1 (19 August 2026) described the codebase as at that date; the changes in revision 2 are itemised in §6.